API Specification

Ref: 1.6
Product: iConnect Plus
Organisation: Cache Digitech
Classification: Internal — Confidential
Version: 2.0
Date: 2026-11-03
Deployment model: On-premises (Cache Digitech premises) · VPN for remote access
Audience: Integrators, security assessors, QA, platform engineering

---

1. Purpose

Describe how the **iConnect Plus REST API** is specified, accessed on **internal infrastructure**, and protected. Machine-readable OpenAPI is generated from the FastAPI application.

---

2. Base URL and versioning

Item	Value
API prefix	`/api/v1`
Production example (via nginx)	`https://172.16.200.30:8443/api/v1`
Internal container URL	`http://api:8000/api/v1`
Protocol	HTTPS at edge; HTTP inside `erp-net`
Format	JSON (UTF-8)
Correlation	`X-Request-ID` response header

Access from the public internet is **not** required; clients reach the API over **LAN or VPN**.

---

3. OpenAPI documentation

Endpoint	Availability	Control
`/docs`	Swagger UI	**`ENABLE_API_DOCS=true`** only
`/redoc`	ReDoc	Same gate
`/openapi.json`	Raw schema	Same gate

Default in code: `enable_api_docs: bool = False` (`ENABLE_API_DOCS`).

Environment	Recommended **`ENABLE_API_DOCS`**	Evidence
Production	`false`	**Template / Pending sign-off**
UAT	`false` or time-boxed `true`	**Template / Pending sign-off**
Development	`true` on dev hosts	Engineer workstations

OpenAPI generation is validated in architecture CI (unique `operationId` constraint).

4. Authentication model

Mechanism	Details
Primary	JWT **access** and **refresh** tokens in **HttpOnly cookies**
Cookie names	`erp_access_token`, `erp_refresh_token` (configurable via env)
Attributes	`Secure`, `SameSite` (default `lax`), path scoped
MFA	TOTP verification endpoint after `mfa_required` login response
Optional SSO	Microsoft OAuth (redirect URIs must match internal URLs)
ESS	Dedicated login routes with optional CAPTCHA

Unauthenticated routes include health checks and auth/login flows only (see route modules).

5. Authorization model

Layer	Behavior
Tenant context	Derived from authenticated user / token
RBAC	`require_permission("<module>.<resource>:<action>")` on protected routes
Catalog	Aggregated from module `permissions.py` → `sec_permission` table
System roles	`SUPER_ADMIN`, `TENANT_ADMIN` packs

Permission codes must align with `apps/web/src/config/modules.ts` (CI gate).

6. Representative endpoint classes

Class	Auth	Example path pattern
Health	None / minimal	`/api/v1/health`
Auth	Public (login), then cookie	`/api/v1/auth/*`
Foundation	Permission + tenant	`/api/v1/foundation/*`
Business modules	Permission + tenant	`/api/v1/{module}/*`
Platform ops	Elevated permissions	`/api/v1/platform/*`
Uploads	Permission + size limits + ClamAV	Module-specific upload routes

Full path list: export OpenAPI with `ENABLE_API_DOCS=true` on an internal staging host.

7. Auth requirements by operation type

Operation	Session	Permission	Tenant scope
GET (read)	Valid access JWT	`:read` (or module-specific)	Enforced in repository
POST (create)	Valid access JWT	`:create`	Enforced
PUT/PATCH (update)	Valid access JWT	`:update` + optimistic `version`	Enforced
DELETE (soft)	Valid access JWT	`:delete`	Soft-delete flag
Workflow approve	Valid access JWT	`:approve` or workflow role	Workflow engine

Platform admin	Valid access JWT	Short-lived privileged token settings	Audit logged

8. Rate limiting and abuse controls

Control	Env variables	Default (dev-friendly)
Login rate limit	`LOGIN_RATE_LIMIT`, `LOGIN_RATE_WINDOW_SECONDS`	`0` (disabled)
API read limit	`API_RATE_LIMIT`	`0`
Write limit	`API_WRITE_RATE_LIMIT`	`120`/min
Upload limit	`API_UPLOAD_RATE_LIMIT`	`30`/min
Account lockout	`ACCOUNT_LOCKOUT_THRESHOLD`	5 failures
Max upload size	`API_MAX_UPLOAD_REQUEST_BYTES`	45 MiB

Production values: **Template / Pending sign-off**

9. Error and security headers

Code	Meaning
401	Missing/invalid session
403	Permission denied
409	Stale version / conflict
422	Validation error
429	Rate limited

Security middleware sets request context; CORS restricted via `CORS_ORIGINS` / regex for known internal frontends.

10. Postman / client testing

Item	Location / procedure
Collection	**Template / Pending sign-off** — export from `/openapi.json` on staging
Environment	Base URL = internal HTTPS; cookies enabled
Test user	Provisioned in UAT tenant — **no production credentials in pack**

11. Integration endpoints

Module-specific outbound integrations (webhooks, external APIs) are documented per module FRD. Secrets stored in encrypted columns or env — not in OpenAPI.

12. Related documents

Ref	Document
3.1	RBAC Matrix
3.2	Authentication and Session Design
2.2	Secure SDLC and Coding Standard

13. Document control

Version	Date	Change
2.0	2026-11-03	On-prem URLs; ENABLE_API_DOCS; cookie auth

Approval: Template / Pending sign-off